

Cómo construir el inventario criptográfico de Coopaburrá

SIO0010 • Técnicas Criptográficas

Especialización en Seguridad de la Información de las Organizaciones



SE ENTREGA

Al inicio de la sesión 2

Fecha: ____ / ____

CÓMO

En equipo de tres

Un archivo por equipo

DEDICACIÓN

3 horas de trabajo

independiente

QUÉ PESA

Parte 1 de 6 del informe

Producto • 30 % del módulo

PUNTO DE PARTIDA

Qué es un inventario criptográfico

Es la lista de **todos los lugares donde la organización usa criptografía**, y de lo que se sabe de cada uno: qué algoritmo, qué llave, quién responde por esa llave y hasta cuándo sirve. Nada más, y nada menos.

No es un inventario de software ni de servidores: eso ya existe y está en la Parte 3 del caso. Lo que no existe en Coopaburrá —y es el hallazgo H8— es el registro de la criptografía que corre *dentro* de esos sistemas. La diferencia es la misma que hay entre saber cuántas puertas tiene un edificio y saber cuántas copias hay de cada llave, quién las tiene en el bolsillo y cuándo se cambió la guarda por última vez.

Por qué es lo primero que van a construir

- 1 Porque no se puede priorizar lo que no se ha contado.** El comité pide una hoja de ruta con \$180 millones. Sin saber cuántos usos de criptografía hay y cuáles están rotos, cualquier orden de inversión es una opinión.
- 2 Porque los otros siete hallazgos aparecieron por casualidad.** Se descubrieron por separado durante dos semanas de diagnóstico. Nadie puede afirmar que no haya un noveno.
- 3 Porque hay que responderle a un tercero.** La Superintendencia llega en septiembre con foco en canales digitales. La primera pregunta de cualquier inspección es qué hay, y la segunda es quién responde por ello.
- 4 Porque es el primer paso de toda transición.** Cambiar un algoritmo por otro —hoy por la caducidad de SHA-1, mañana por la llegada de la computación cuántica— empieza siempre por la misma pregunta: dónde está ese algoritmo. La sesión 6 vuelve sobre esto.

LA CONFUSIÓN MÁS FRECUENTE

Un inventario **registra**, no **juzga** ni **propone**. Si al llenar una fila escriben «habría que guardar esa llave en otro sitio», están adelantando la entrega 2. Anótenlo aparte si quieren, pero la fila solo dice dónde está la llave hoy. La tentación de arreglar mientras se cuenta es justamente lo que impide terminar de contar.

Lo que este documento no es

No es un diagnóstico

No dice si algo está bien o mal. Eso llega con las entregas 2 a 5, sesión por sesión.

No es un plan

No propone cambios, costos ni plazos. La hoja de ruta priorizada es la entrega 6.

No es un examen

No se evalúa que esté completo. Es imposible completarlo: falta información que nadie en Coopaburrá tiene.

REGLA DE TRABAJO DEL MÓDULO

No carguen el caso, el inventario ni fragmentos de las evidencias en servicios en línea de terceros. Es la regla 5 del caso y es, además, una costumbre profesional: lo que se pega en un sitio público deja de ser confidencial en ese instante.

EL ENTREGABLE

Qué se entrega exactamente

Tres piezas en un solo archivo: la tabla del inventario, la lista de preguntas pendientes y media página de lectura. Ninguna de las tres es opcional.

Pieza 1 · La tabla del inventario

Qué es	Una tabla de seis columnas —las que verán en las páginas 4 y 5— con una fila por cada uso de criptografía que identifiquen en Coopaburrá.
Cuántas filas	Como mínimo doce , y los ocho sistemas de la Parte 3 deben aparecer al menos una vez. Si les salen menos de doce, no buscaron bien; si les salen veinte, mejor.

Pieza 2 · Las preguntas pendientes

Qué es	Una lista de todo lo que quedó marcado como desconocido , con dos datos obligatorios por pregunta: a quién hay que preguntarle —una persona de la Parte 2 o un proveedor nombrado— y cómo se comprobaría .
Por qué	Es la pieza que más pesa en la calificación. Un «no sé» con destinatario y método es trabajo profesional; un «no sé» solo es una casilla vacía.

Pieza 3 · La lectura del inventario

Qué es	De tres a cinco frases que respondan: ¿qué revela el conjunto que no revelaba ninguna fila por separado?
Ejemplo de lo que se busca	«De los N usos identificados, M no tienen responsable nombrado» es una lectura. «El portal usa TLS 1.0» es una fila.

ANTES DE ESCRIBIR LA PRIMERA FILA

Queda una decisión por tomar, y determina todo lo demás: **qué cuenta como una fila**. Está en la página siguiente. Equivocarse ahí obliga a rehacer la tabla entera.

EL ENTREGABLE · LA UNIDAD DE REGISTRO

Qué cuenta como una fila

La unidad de registro **no es el sistema: es el uso**. Un mismo sistema puede generar varias filas, y casi siempre las genera. El portal de asociados, por ejemplo, produce por lo menos tres usos distintos, con algoritmos distintos, llaves distintas y problemas distintos:

USO · UNA FILA CADA UNO	POR QUÉ NO PUEDEN IR JUNTOS
Portal · canal con el navegador	Protege datos en tránsito . Lo define el servidor web y se comprueba mirando el canal (Evidencia A).
Portal · contraseñas guardadas	Protege datos en reposo . Lo define el código de la aplicación y vive en la base de datos (H1).
Portal · certificado y quién lo emite	Da autenticidad del servidor . Depende de una autoridad certificadora interna y de una llave privada que está en otro edificio del problema (H5).

CÓMO SABER SI UNA FILA DEBE PARTIRSE EN DOS

Si al llenar la columna del algoritmo tienen que escribir dos algoritmos, o al llenar la de la llave tienen que hablar de dos llaves distintas, **son dos filas**. Es la regla práctica y no falla.

Cómo repartir las tres horas

45'	60'	30'	30'	15'
Leer y marcar las Partes 3, 7, 8 y 10, y el anexo técnico	Listar los usos y llenar las columnas 1 a 4	Columnas 5 y 6: responsable y vigencia	Preguntas pendientes con destinatario	Escribir la lectura del inventario

Háganlo en ese orden. Llenar el responsable mientras se buscan los algoritmos duplica el trabajo, porque los responsables están todos en una sola página del caso.

Cómo encontrar los usos sin que se les escape ninguno

Recorran los ocho sistemas de la Parte 3 y háganle a cada uno las mismas tres preguntas. Cada respuesta afirmativa es una fila del inventario.

¿Qué viaja?

Todo dato que sale de donde está: el canal del portal, el de la aplicación móvil, el enlace con el procesador de tarjetas, el correo, y el disco que sale en carro hacia Sabaneta los viernes.

¿Qué se guarda?

Todo dato que se queda quieto: la base del core, los respaldos, las contraseñas del portal, las de los 380 empleados y el millón de documentos del gestor.

¿Qué se firma?

Todo lo que alguien va a tener que probar después: las operaciones de la aplicación, los pagarés hipotecarios y el certificado con el que el portal dice ser quien es.

SI UN SISTEMA NO RESPONDE A NINGUNA DE LAS TRES

Escríbanlo igual, con «**sin uso criptográfico identificado**». Un sistema ausente de la tabla no se distingue de un olvido, y el que lea el inventario dentro de seis meses no va a poder saber cuál de las dos cosas fue.

LAS SEIS COLUMNAS · 1 DE 2

Qué va en cada casilla

Cada columna responde una pregunta y solo una. Si una casilla responde dos, está mal puesta.

1 Dónde está la criptografía

PARTE 3

QUÉ RESPONDE	¿En qué sistema, canal o proceso concreto se está usando?
CÓMO SE LLENA	Sistema de la Parte 3 + el uso, separados por un punto. El uso es lo que distingue una fila de otra.
SIRVE	« Respaldos · cifrado del archivo diario antes de copiarlo al disco externo »
NO SIRVE	« Respaldos » — ahí hay al menos dos cosas: el archivo cifrado y el disco que viaja a Sabaneta.

2 Para qué sirve ahí

LO DEDUCEN USTEDES

QUÉ RESPONDE	¿Cuál de los cuatro servicios pretende dar: confidencialidad, integridad, autenticidad o no repudio?
CÓMO SE LLENA	Escriban el servicio que se busca con ese uso. Si sospechan que no lo logra, añadan la palabra pretende y déjenlo ahí: la demostración es de las entregas siguientes.
OJO	Un uso puede pretender dos servicios. Escribanlos los dos. Lo que no vale es escribir «seguridad».
SIRVE	« Autenticidad del mensaje. Pretende no repudio, pero la llave es compartida por los 142.000 asociados »
NO SIRVE	« Proteger los datos » — no distingue entre esconder un dato y probar quién lo firmó.

3 Qué algoritmo y qué versión

PARTES 3 Y 8

QUÉ RESPONDE	¿Qué se está ejecutando exactamente? Nombre, modo de operación y longitud de llave. Si es un protocolo, la versión.
CÓMO SE LLENA	Con el máximo detalle que permita la evidencia, y citando de dónde salió. AES-256-CBC es mejor que AES ; TLS 1.0, 1.1 y 1.2 es mejor que TLS .
DESCONOCIDO	Es respuesta válida y es la más reveladora del inventario. Pero escriban qué se desconoce, no solo la palabra: no es lo mismo ignorar el algoritmo que ignorar su versión.
SIRVE	« AES-256-CBC. La llave se deriva de una contraseña con la opción -k de OpenSSL; el método de derivación no consta » · Evidencia C
NO SIRVE	« Cifrado fuerte » o « estándar de la industria » — son lo que dice un folleto, no lo que corre en un servidor.

SOBRE LA COLUMNA 3 Y LAS CUATRO EVIDENCIAS

La Parte 8 del caso trae cuatro salidas técnicas reales del diagnóstico. Son la única fuente dura de esta columna y alimentan cuatro filas distintas: el canal del portal (A), las contraseñas (B), los respaldos (C) y la firma de la aplicación (D). Todo lo demás del inventario se llena con la Parte 3, con los hallazgos o con la palabra desconocido.

LAS SEIS COLUMNAS · 2 DE 2

La llave, el responsable y el plazo

Estas tres columnas son las que convierten una lista de algoritmos en un inventario. Son también las que Coopaburrá no puede responder, y por eso existe el caso.

4 Qué llave lo protege

PARTES 7 Y 8

QUÉ RESPONDE	¿Cuántas llaves hay, quién las conoce y dónde están guardadas?
CÓMO SE LLENA	Los tres datos, en ese orden. «Una sola» y «una por usuario» son mundos distintos, y la diferencia entre ellos es la mitad del caso.
CUIDADO	La contraseña de un asociado no es una llave criptográfica: es un secreto del usuario. La llave es lo que usa el sistema para cifrar o firmar. Confundirlas es el error más común de esta columna.
SIRVE	«Una sola, idéntica en todas las versiones desde marzo de 2023. Está incrustada en el código de la aplicación, que cualquiera descarga de la tienda. La conoce, en la práctica, cualquiera que la descompile»
NO SIRVE	«La maneja sistemas» — no dice cuántas hay ni dónde están.

5 Quién responde por ella

PARTE 2

QUÉ RESPONDE	¿Qué persona, con nombre y cargo, responde si esa llave se pierde o se filtra?
CÓMO SE LLENA	Nombre y cargo de alguien de la Parte 2. Si quien responde de hecho no tiene esa función asignada, escríbalo así: «de hecho, sin asignación formal» .
SI NO HAY	«Sin responsable asignado» es una respuesta, y en Coopaburrá va a ser la más repetida. No la sustituyan por el nombre del que más se le parezca.
SIRVE	«Édison Zapata Gil, Jefe de Infraestructura, de hecho y sin asignación formal»
NO SIRVE	«TI», «el proveedor», «la gerencia» — un área no responde: responde una persona.

6 Cuándo vence o se rota

PARTES 7 Y 10

QUÉ RESPONDE	¿Hasta cuándo sirve lo que hay hoy?
TRES RESPUESTAS VÁLIDAS	a) una fecha conocida; b) «nunca se ha rotado», y entonces desde cuándo ; c) «no aplica», y por qué.
EL DATO QUE SE OLVIDA	Algunos usos no vencen: tienen que durar . Un pagaré firmado este año debe seguir probando algo en 2039. Esa fecha va en esta columna.
SIRVE	«Nunca se han rotado. Cargadas en la puesta en marcha de 2019; el fabricante recomienda cada dos años»
NO SIRVE	Dejarla vacía . Si no se sabe, va «desconocido» y sube a las preguntas pendientes.

EJEMPLOS RESUELTOS · 1 DE 2

Una fila donde casi todo se sabe

Así se ve una fila terminada. Al lado de cada casilla está la parte del caso de donde salió el dato: esa referencia es obligatoria en la entrega.

Ejemplo A · El respaldo diario	
1 · Dónde está	Respaldos · cifrado del archivo de respaldo diario antes de copiarlo al disco externo Parte 3, fila «Respaldos»
2 · Para qué sirve	Confidencialidad de la base de datos fuera del servidor Deducido
3 · Algoritmo	AES-256-CBC, invocado con openssl enc . La llave se deriva de una contraseña con la opción -k ; el método de derivación no consta en la evidencia Evidencia C
4 · Qué llave	Una sola. Está en /opt/backup/llave.txt , en el mismo directorio que los respaldos, y se pasa en la línea de comandos, por lo que queda visible para cualquier usuario que liste los procesos. La copia semanal viaja a Sabaneta con la llave en el mismo disco H4 y Evidencia C
5 · Quién responde	Édison Zapata Gil, Jefe de Infraestructura, de hecho y sin asignación formal Parte 2
6 · Vigencia	Nunca se ha rotado. No hay procedimiento ni fecha; se desconoce desde cuándo es la misma H4 · queda como pregunta pendiente

LO QUE ESTA FILA HACE BIEN

Dice lo que hay y señala con precisión lo que no se sabe —el método de derivación y la antigüedad de la llave— sin proponer ninguna solución. **No aparece la frase «hay que sacar la llave de ahí»**, aunque a cualquiera le esté ardiendo en la punta de los dedos. Eso es la entrega 2, en la sesión 3.

Un error que se repite en esta fila

Muchos equipos escriben en la columna 3 «AES-256-CBC, cifrado fuerte, correcto». Las tres primeras palabras son el inventario; las otras dos son un juicio, y además es un juicio prematuro: la sesión 2 va a mostrar que en esa misma línea de comando hay **al menos tres problemas distintos**, y que solo uno es que la llave esté en un archivo de texto. Registren la línea completa y dejen que el juicio llegue con el tema.

```
openssl enc -aes-256-cbc -in respaldo_diario.sql -out respaldo_diario.enc -k $(cat /opt/backup/llave.txt)
```

Evidencia C del caso. Cópienla tal cual en la fila: el inventario vale por lo que registra, y esta línea contiene más información que cualquier resumen que hagan de ella.

EJEMPLOS RESUELTOS · 2 DE 2

Una fila donde casi nada se sabe

Esta es la fila que más cuesta escribir y la que más vale. Registrar bien una ausencia es más difícil que registrar un algoritmo.

Ejemplo B · La firma de los créditos hipotecarios	
1 · Dónde está	Gestor documental · firma de contratos y pagarés de crédito hipotecario en PDF Parte 3, fila «Gestor documental»
2 · Para qué sirve	Pretende autenticidad y no repudio: probar que el documento lo firmó su titular y que no se ha alterado Deducido · es la pregunta del apoderado
3 · Algoritmo	Ninguno. Es la imagen de una firma capturada en tableta, insertada en un PDF. No hay firma digital, ni sello de tiempo, ni entidad de certificación H7
4 · Qué llave	No existe. No hay nada que custodiar, y esa ausencia es precisamente el hallazgo H7
5 · Quién responde	Sin responsable asignado. El gestor documental lo opera Coopaburrá, pero el caso no nombra a nadie a cargo de la validez de esos documentos Parte 3 · pregunta pendiente para Édison Zapata Gil
6 · Vigencia	No se rota: tiene que durar. El crédito más largo firmado este año vence en 2039, y hasta entonces el documento debe conservar valor probatorio Parte 10

Las tres maneras correctas de escribir «no sé»

SITUACIÓN	CÓMO SE REGISTRA
No existe	« Ninguno » o « no existe ». Es una afirmación, no una duda: el caso permite sostenerla. Ejemplo: no hay firma digital en los pagarés.
Existe pero no consta	« Desconocido » + qué se desconoce exactamente. Ejemplo: el correo está en nube pública, seguramente cifrado, pero el caso no dice con qué ni quién tiene esas llaves.
Lo dice alguien, no está comprobado	« Declarado por..., no verificado ». Ejemplo: la sal c00pab2019 es lo que la fábrica de software declara en su documentación; que de verdad se aplique, y en qué orden, está por comprobar.

LA DISTINCIÓN QUE SEPARA UN BUEN INVENTARIO DE UNO MALO

«**No hay**» y «**no sé**» no son lo mismo. El primero es un hallazgo y entra al informe; el segundo es una tarea y entra a las preguntas pendientes. Confundirlos hace que el comité crea que algo está resuelto cuando solo está sin mirar —y es exactamente así como Coopaburrá llegó a tener ocho hallazgos que nadie vio venir.

MÉTODO

Dónde está cada dato en el caso

El inventario se construye con el caso, su **anexo técnico** y algunas deducciones. Estas son las fuentes, y qué columna alimenta cada una.

PARTE DEL CASO	QUÉ ENCUENTRAN AHÍ	QUÉ COLUMNA ALIMENTA
Parte 2 Quién es quién	Las ocho personas disponibles, de quién dependen y qué deciden	Columna 5. Es la única fuente de responsables. Incluye a un ex contratista que ya no trabaja allí y cuyo computador sigue encendido: conviene no olvidarlo.
Parte 3 Qué tiene montado	Los ocho sistemas, quién los opera y su descripción general	Columna 1. Es el punto de partida: cada sistema genera una o más filas. Ninguno puede quedarse por fuera. El detalle criptográfico de cada uno está en el anexo.
Parte 7 Los ocho hallazgos	H1 a H8, con el detalle de qué se encontró en cada uno	Columnas 3, 4 y 6. Casi todo lo que se sabe de llaves está aquí. Siete de los ocho hallazgos aportan al menos una fila.
Parte 8 Evidencia técnica	Cuatro salidas reales: el canal del portal, la tabla de usuarios, la línea del respaldo y el código de la aplicación	Columnas 3 y 4. Es la fuente dura. Cuando una evidencia contradice lo que dice un informe anterior, gana la evidencia.
Anexo técnico Uno por sistema	Un artefacto por sistema — configuración, volcado o acta— con el algoritmo y la llave que la Parte 3 no daba	Columnas 3 y 4. Convierte casi todos los «desconocido» en dato real: AES-XTS en el disco, 3DES en los cajeros, MD4 en el directorio, TLS 1.3 con el procesador.
Parte 10 Fechas	Vencimientos, ventana de mantenimiento y el horizonte de 2039	Columna 6. Dos fechas son inmediatas: el certificado del portal vence el 14 de junio de 2026 y la Superintendencia llega en septiembre.

Lo que sigue sin determinar, aun con el anexo

El anexo resolvió casi todo. Lo que queda son pocas cosas, y son justamente el material de las preguntas pendientes. No las inventen: márkennas con destinatario.

- La **gestión de llaves del procesador de tarjetas** del lado del proveedor: el anexo muestra que el canal es TLS 1.3, pero lo que el proveedor hace con sus llaves está bajo su alcance PCI.
- El **cifrado en reposo del correo** en la nube: el tránsito usa STARTTLS, pero el reposo lo gestiona el proveedor.
- Si la **sal declarada del portal** se aplica de verdad. La documentación la declara; la evidencia B sugiere otra cosa. Comprobarlo es trabajo de la sesión 3.
- Qué hay en el **computador del ex contratista**, además de la llave privada de la autoridad certificadora interna.

CÓMO SE ESCRIBE UNA PREGUNTA PENDIENTE

Tres campos, siempre: **qué se necesita saber · a quién se le pregunta · cómo se comprobaría**. Por ejemplo: «¿La sal declarada por la fábrica se aplica de verdad, y antes o después del resumen? · Yeison Cardona, Coordinador de Desarrollo · Revisando el código de registro de usuario del portal». Una pregunta sin destinatario no es una pregunta: es una queja.

EVALUACIÓN

Con qué criterio se califica

No se evalúa que el inventario esté completo: es imposible completarlo. Se evalúa **qué tan honesto y qué tan utilizable** es lo que entregan.

CRITERIO	PESO	QUÉ SE MIRA
Tratamiento de lo desconocido	30 %	Las casillas sin dato están marcadas —no vacías—, distinguen «no hay» de «no se sabe», y cada una tiene destinatario y forma de comprobación.
Cobertura	25 %	Los ocho sistemas de la Parte 3 aparecen al menos una vez. Hay doce usos o más. Los sistemas que dan varios usos están desglosados.
Precisión del registro	25 %	Cada dato está respaldado por el caso y dice de qué parte o evidencia salió. Los algoritmos están escritos con modo y longitud. No hay datos inventados.
Lectura del inventario	20 %	Las tres a cinco frases dicen algo que ninguna fila dice por separado, y se abstienen de proponer soluciones.
Total	100 %	Parte 1 de las seis que componen el informe de aseguramiento criptográfico

LAS TRES FORMAS DE PERDER PUNTOS SIN DARSE CUENTA

Rellenar. Escribir «AES-256» donde el caso no dice qué algoritmo se usa, porque suena razonable, es el error más grave del ejercicio: convierte una pregunta abierta en un dato falso, y el que lea el informe después ya no va a ir a comprobarlo. **Resolver.** Proponer cambios en las filas adelanta trabajo que se evalúa en otra entrega y estorba en esta. **Agrupar.** Una fila por sistema en vez de una por uso esconde exactamente los detalles que el inventario existe para revelar.

Antes de entregar

- ☐ Los ocho sistemas de la Parte 3 aparecen al menos una vez en la tabla.
- ☐ Hay **doce filas o más**, y ninguna mezcla dos algoritmos o dos llaves.
- ☐ Ninguna casilla está **vacía**: todas tienen dato, «ninguno» o «desconocido».
- ☐ Cada dato técnico dice **de qué parte o evidencia del caso** salió.
- ☐ Todos los responsables son **personas con nombre y cargo** de la Parte 2, o dicen «sin responsable asignado».
- ☐ Cada «desconocido» aparece en la **lista de preguntas pendientes**, con destinatario y forma de comprobación.
- ☐ La columna 6 tiene **fecha, «nunca se ha rotado» + desde cuándo, o «no aplica»** con justificación.
- ☐ No hay **ninguna propuesta de solución** dentro de la tabla.
- ☐ La **lectura del inventario** está escrita y cabe en media página.
- ☐ El archivo lleva el **nombre del equipo y de sus tres integrantes**.

PLANTILLA

Para trabajar en clase

Equipo: _____ Fecha: ____ / ____

Integrantes: _____

1 · DÓNDE ESTÁ	2 · PARA QUÉ	3 · ALGORITMO Y VERSIÓN	4 · QUÉ LLAVE	5 · QUIÉN RESPONDE	6 · VENCE O ROTA

Preguntas pendientes

QUÉ SE NECESITA SABER	A QUIÉN SE LE PREGUNTA	CÓMO SE COMPROBARÍA

RECUERDEN

Esta hoja es para pensar en clase. La entrega es un archivo del equipo con las tres piezas —tabla, preguntas pendientes y lectura del inventario—, al inicio de la sesión 2. Lo que no alcancen en las tres horas de trabajo independiente se nota, y se nota sobre todo en la columna 5.